Consulting Cockpit v4
セキュリティ検証 報告書

外部からの侵入試験と、内部の防御機能の動作確認

実施日：2026年8月13日〜14日　／　対象：開発環境（localhost:4200 ほか）

この報告書は、実際に開発環境へリクエストを送って挙動を確かめた結果をまとめたものです。「実施した試験と結果」「見つかった弱点」「直した弱点」「残るリスク」「未検証の範囲」を分けて記載しています。試していない事項を「確認済み」とは書いていません。暗号化の強度の数値は実装の設定値に基づきます。

1. 試験の進め方

- 対象は開発環境（Web: localhost:4200）。本番公開環境ではありません。
- 試験は3段階で実施しました。
  - フェーズA：認証なしで外部から送れる攻撃（ヘッダ・横断呼び出し・総当たり・情報露出 等）
  - フェーズB：試験用アカウントでログインした状態での攻撃（他人のデータへの到達・罠入力・時刻偽装 等）
  - フェーズC：防御強化の実装後に、効いているかの再確認
- あわせて、防御機能（H1〜H9 と呼ぶ一連の強化）をコードと動作の両面で確認しました。

2. 実施した試験と結果（一覧）

「侵入可否」は攻撃者視点の結果です。「防いだ」は防御が効いたことを意味します。

フェーズA（未認証での攻撃）

試験	結果	内容
セキュリティヘッダの確認	**要対応**	CSP 等のヘッダが HTTP レスポンスに無い（meta タグの CSP はあり）
CORS（他サイトからの呼び出し）	**弱点**	見知らぬオリジンをそのまま許可して返す設定だった
サインインの総当たり 25回	**防御追加**	当初は回数制限なし → 後述の強化で制限を追加
利用者の存在推測	**防いだ**	既知/未知のメールで応答・時間に差が出ないことを確認
新規登録の別経路	**防いだ**	サインアップは無効化済み（400 で拒否）
未認証での全手続き呼び出し	**防いだ**	動作確認用の `ping` 以外は全て 401
セッション偽造 5パターン	**防いだ**	乱数・署名なし・空・別名・Bearer偽造の全てが 401
ファイル露出	**弱点**	開発サーバーが `.env` や API のソース等を配信していた
メソッド改変・存在しない手続き	**防いだ**	GET は 405、存在しない手続きは 404
8MB の大きな本体	**防いだ**	未認証のため 401 で即拒否（53ms）

プロトタイプ汚染の試行	**影響なし**	注入しても以後の応答に影響なし

フェーズB（ログイン状態での攻撃）

試験	結果	内容
他人のデータへの横取り	**防いだ**	同じ論理IDで push しても自分の領域にしか入らない
罠入力（負の数・巨大な数・型ちがい・パース不能 等）	**防いだ**	いずれも 400 で検証エラー。例外の漏出なし
巨大な暗号文（4MB）	**防御追加**	当初は通った → 上限 256KB を追加し 400 で拒否
SQL 文の混入	**防いだ**	パラメータ化のため影響なし
監査ログの時刻偽装	**仕様として記録**	時刻はクライアント申告を受け入れる設計（後述）
失効端末の再登録	**防いだ**	失効後の push は 403。再登録しても失効状態を維持
盗んだクッキーで別端末のふり	**限界として記録**	同一クッキーは別UA/別IPでも通る（後述）
ログイン履歴の60連打	**防御追加**	当初は無制限 → 記録数に上限を設け古いものを破棄

フェーズC（強化後の再確認）

試験	結果	内容
名簿にないサイトからの呼び出し	**防いだ**	許可リスト外のオリジンは 403「許可されていない接続元です。」
vault/status に鍵の材料が出ないか	**防いだ**	ソルトや検証子は返さないことを確認
解錠材料の要求を30回連続	**防いだ**	20回で打ち止め、21回目以降は 429
暗号文の大きさ制限	**防いだ**	4MB は 400、64KB は 200
監査ログ切り詰め後の連鎖検証	**防いだ**	途中の番号から正しく検証（起点を返す）
端末失効で他端末が切れるか	**防いだ**	失効直後に他セッションは 401、手元は継続
合言葉の当てずっぽう 20回	**防いだ**	7回目以降は 429 で制限

3. 見つかった弱点と、直した内容（H1〜H9）

見つかった弱点に対し、9件の強化を実装しました。いずれもコードの確認と、実環境での動作確認を行っています。

番号	対応した弱点	直した内容と検証
H1	新規登録の開放	サインアップを無効化。利用者は登録されたオーナーのみに限定
H2	接続元の制限不足	信頼する接続元を名簿化（localhost・プレビューURL・アプリ固有のスキーム）。名簿外は 403
H3	サインインの総当たり耐性なし	サインインに回数制限（300秒に8回）を追加。超過は 429
H4	解錠まわりの情報露出と無制限	状態の応答から鍵の材料を除外。解錠材料の要求は15分に20回まで・超過で5分待機。検証で 200×20回＋429×5回 を確認
H5	端末を失効しても他端末が残る	失効時に他のセッションを即時削除。検証で、失効後に他セッションが 401 になることを確認
H6	大きなデータでサーバーに負荷	1件あたりの暗号文を 256KB に制限（sync と vault の両方）。262,154バイトは 400、1,000バイトは 200 を確認
H7	取込データによる汚染	バックアップ取込に 20MB 上限・危険なキー（__proto__ 等）の除去・深さ制限を追加
H8	デスクトップ版のファイル読み書きが無制限	読み書きを、利用者がダイアログで選んだ場所に限定
H9	監査ログを切り詰めると検証が壊れる	切り詰め後の先頭番号を起点に検証するよう修正。検証で整合することを確認

4. 残るリスク（直していない・直せないもの）

以下は今回の対応では直していない、または構造上そのまま残る事項です。公開・運用の判断材料としてください。

項目	区分	説明
CORS の全開放（基盤側）	**残置**	サーバーの土台部分（編集不可）が全オリジンを許可する。アプリ側の接続元チェック（H2）で実害は抑えているが、土台自体は変更していない
セキュリティヘッダ未付与	**残置**	CSP 等を HTTP ヘッダで出すにはサーバー側の設定が必要。現状は meta タグの CSP のみ
セッションと端末の非結合	**残置**	盗まれたクッキーは別端末・別IPでもそのまま使える。トークン漏えい時の限界
監査ログの時刻はクライアント申告	**仕様**	時刻は端末の申告を受け入れる設計。改ざん検知は連鎖で担保するが、時刻そのものの真正性は保証しない
開発サーバーのソース配信	**開発環境のみ**	vite の開発サーバーが `.env` やソースを配信しうる。本番ビルドでは発生しない想定だが、公開時は別途確認が必要

5. 未検証の範囲

以下は環境の制約により、今回は確認できていません。「問題ない」と判断したものではありません。

- **実機モバイルでの動作**：Expo アプリの実機・エミュレータでの確認は未実施。バンドルが生成されること（エラーなく200で返る）までの確認に留まる

- **デスクトップ（Electron）の画面**：画面の無い環境のため GUI の目視確認は未実施
- **開発ビルドでの Google サインイン**：モバイルの Google サインインは、Expo Go では構造的に使えず、開発ビルド（eas build）またはインストール版が必要。その実サインインは未検証
- **本番公開環境**：今回の対象は開発環境。公開時の挙動（HTTPS・ヘッダ・ドメイン）は別途確認が必要

6. まとめ

- 外部からの侵入試験（未認証・ログイン状態）と、防御強化の再確認を実施しました。
- 見つかった弱点に対し、認証・接続元・回数制限・データサイズ・取込防御・端末管理・監査の9件を強化し、動作で確認しました。
- 一方で、CORS の土台設定・セキュリティヘッダ・セッションと端末の結合など、今回の範囲では直せない事項が残っています。公開前に、本番環境での再確認をおすすめします。

> 本報告書は開発環境への検証結果であり、絶対的な安全性を保証するものではありません。新たな機能追加や依存関係の更新により状況は変わります。重要な変更のたびに再検証することをおすすめします。